



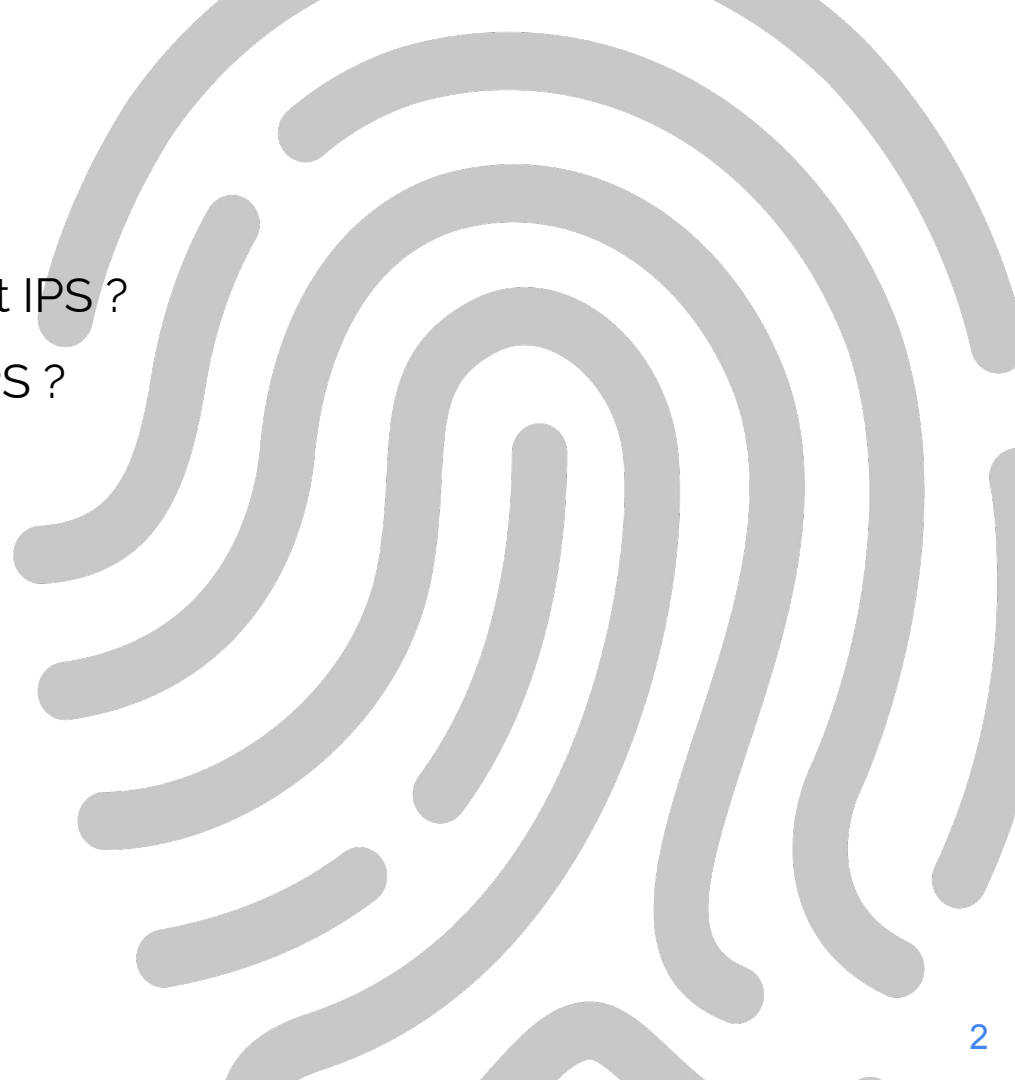
IDS/IPS



IDS-IPS

Savez-vous ce que veut dire IDS et IPS ?

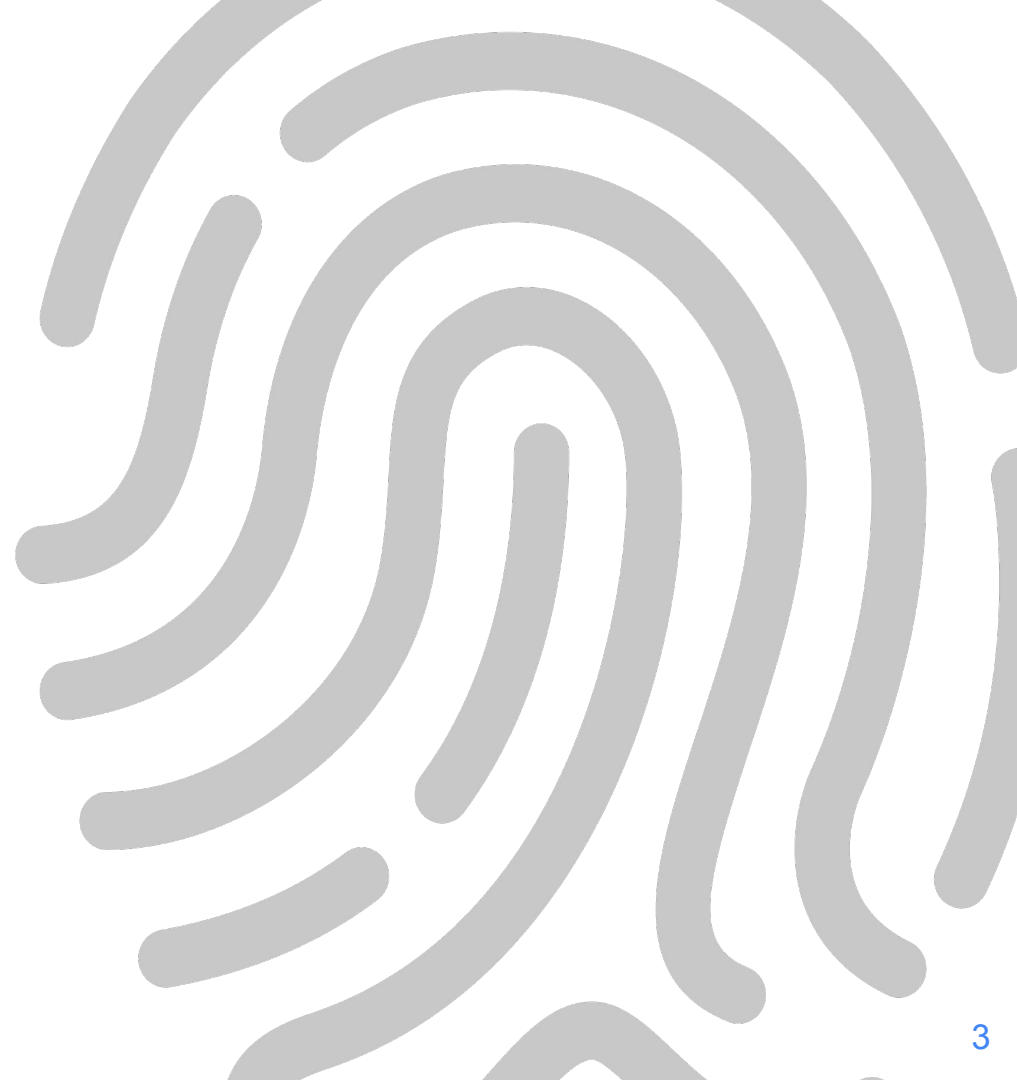
Connaissez-vous des IDS et des IPS ?

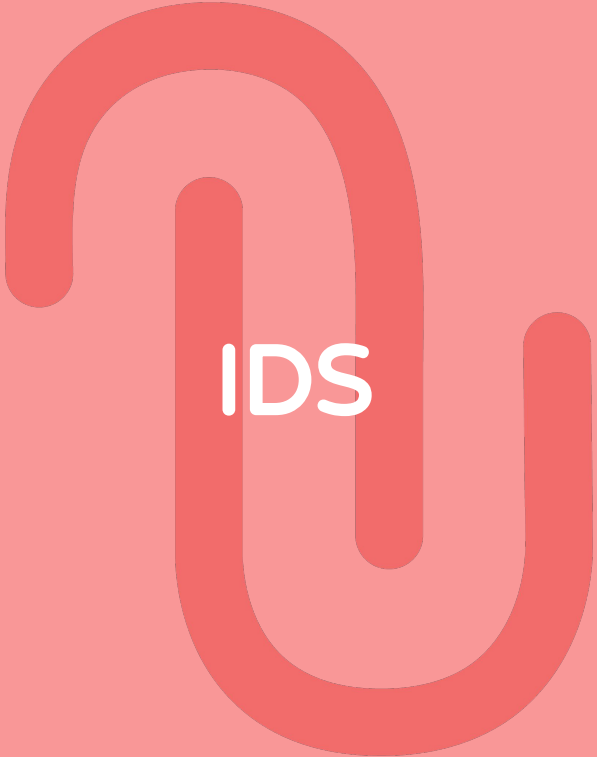




Plan

- 1 - IDS
- 2 - IPS
- 3 - Méthodes de détection
- 4 - Types de détection





IDS



IDS (Intrusion Detection System)

Les systèmes de détection des intrusions **analysent l'activité** pour **détecter des signatures** correspondant à des cyber-attaques connues.

Une intervention humaine ou un autre système doit prendre ensuite le relais pour examiner les résultats et déterminer les actions à mettre en œuvre.

Il existe 2 grandes familles d'IDS :

- **NIDS** (*Network Intrusion Detection Systems*)
- **HIDS** (*Host Intrusion Detection Systems*)



Usage d'un IDS

Un IDS peut détecter une possible attaque, il **peut alerter mais il ne peut pas l'interrompre**.

Il constitue un très bon outil d'analyse pour une équipe CSIRT (*Computer Security Incident Response Team*) qui va s'occuper de la réponse à l'incident pour contrer une attaque.

De même, il sert également à l'analyse post-mortem, qu'on effectuera une fois l'incident clos.

Il est utile pour voir le chemin que l'attaquant a pris.



NIDS

Un **système de détection d'intrusions réseau** (ou *Network Intrusion Detection Systems*) analyse en temps réel le trafic qu'il capte à l'aide d'une sonde (carte réseau en mode *promiscuous*) $\Rightarrow$ surveillance du flux réseau.

Les paquets sont décortiqués puis analysés $\Rightarrow$ recherche de chaîne de caractères que l'on suspecte.

Un NIDS nécessite un matériel dédié.

Il ne peut pas empêcher les paquets d'entrer sur le réseau.



Mode d'utilisation NIDS

En cas de détection d'intrusion, en **mode actif** :

- Il peut y avoir une alarme
- Des alertes peuvent être envoyées.

En **mode passif** :

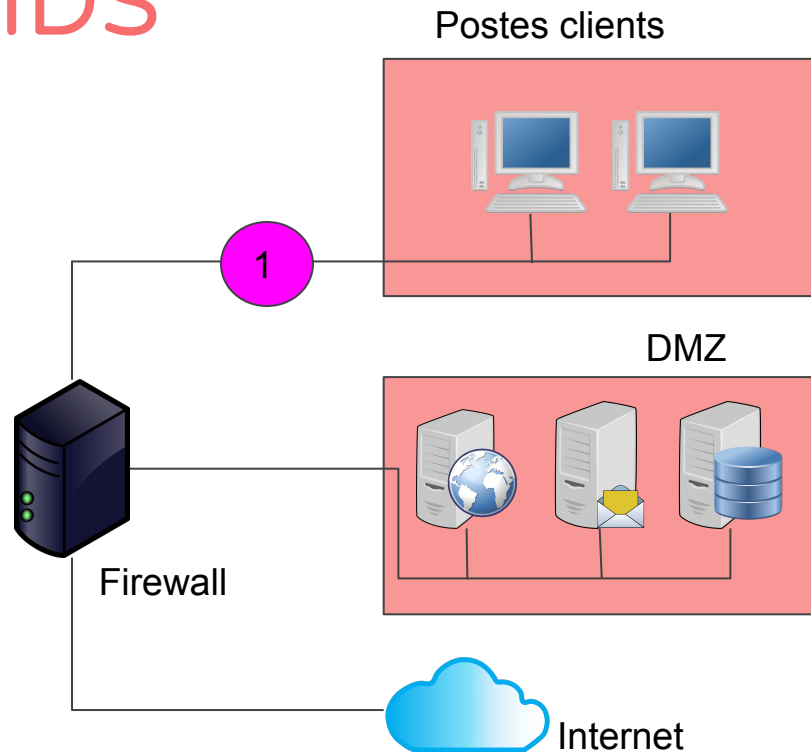
- Archivage de l'action détectée.



Emplacement d'un NIDS

Emplacement 1 (entre clients et firewall, sur le port monitoring d'un switch ou en passerelle sur un routeur) :

- CR des attaques internes, provenant du réseau local de l'entreprise (judicieux -> 80 % des attaques).
- En cas de contamination du parc par virus ou trojans (navigation internet...) ils pourront être facilement identifiés puis éradiqués.

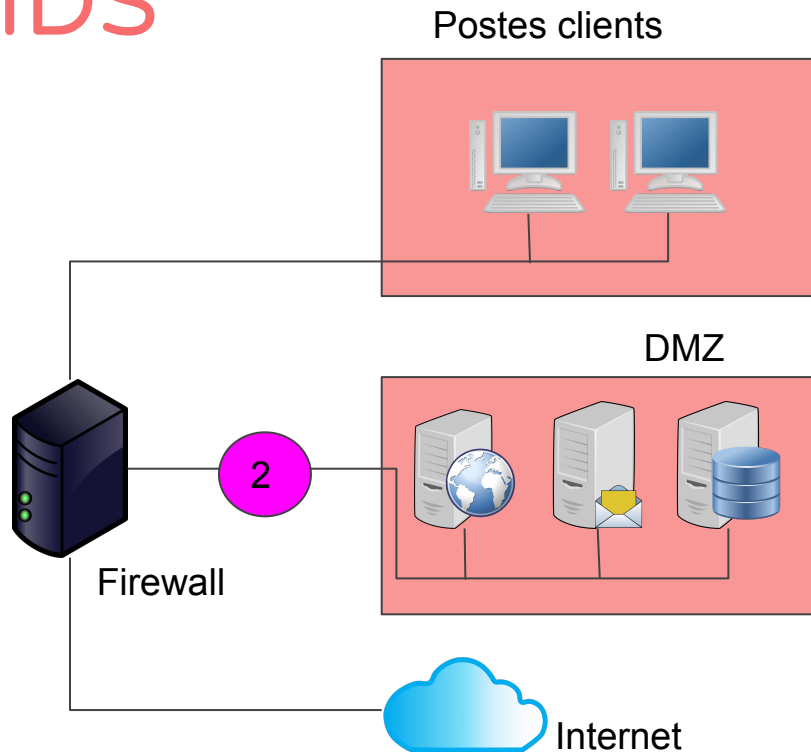




Emplacement d'un NIDS

Emplacement 2 (entre DMZ et firewall) :

- Détection des attaques qui n'ont pas été filtrées par le firewall.
- Logs plus clairs à consulter puisque les attaques bénignes ne sont pas recensées (filtrée sur le firewall).

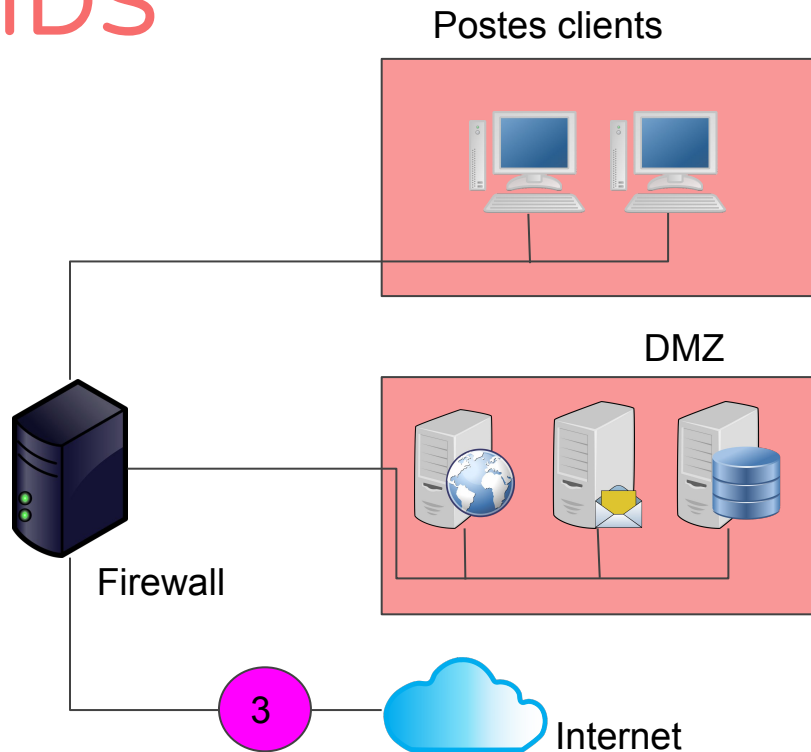




Emplacement d'un NIDS

Emplacement 3 (zone internet) :

- Détection de l'ensemble des attaques frontales, provenant de l'extérieur (en amont du firewall).
- Beaucoup d'alertes remontées
- Gros volume de logs difficilement exploitable





Avantages

- Surveillance possible de grands réseaux
- Le déploiement sur un réseau existant → peu d'impact
- Habituellement dispositifs passifs → pas d'interférence sur les opérations normales d'un réseau
- Dispositif très sûr contre une attaque (invisible pour les attaquants)

Inconvénients

- Difficultés de traitement de tous les paquets sur un grand réseau.
- Si beaucoup de trafic → Difficultés pour reconnaître des attaques
- Pas d'analyse possible de flux chiffré (ex : VPN)
- La plupart du temps : ne peut pas indiquer si une attaque est réussie ou non



HIDS

Un **système de détection d'intrusions machine** (ou *Host Intrusion Detection Systems*) réside sur un hôte particulier.

La gamme des HIDS couvre une grande partie des OS : Windows, Solaris, Linux, HP-UX, IBM AIX, ...

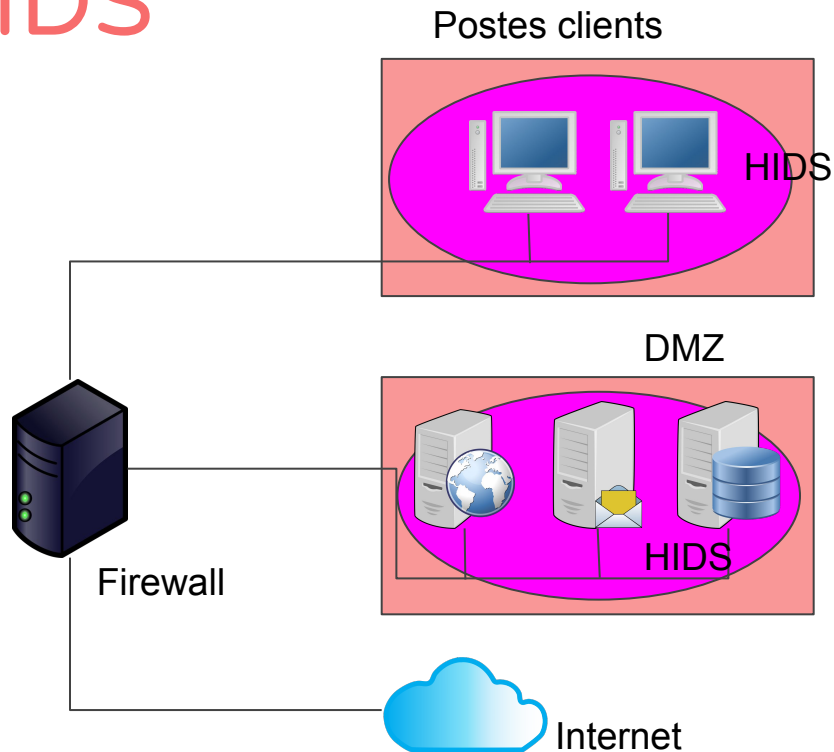
Le HIDS est très dépendant du système sur lequel il est installé.



Emplacement d'un HIDS

En général, le HIDS est placé sur une machine sensible, susceptible de subir des attaques et possédant des données sensibles pour l'entreprise :

- Serveurs web
- Serveurs applicatifs
- Machines hôtes sensibles





Avantages

- Surveillance des événements locaux jusqu'au host et détection des attaques non-vues des NIDS
- Fonctionne dans un environnement avec un trafic réseau chiffré
- Détection possible des attaques concernant l'intégrité logicielle (chevaux de Troie)

Inconvénients

- Chaque hôte est configuré selon la surveillance souhaitée → Gestion difficile
- Peut être attaqué et neutralisé (DoS)
- Peut être contourné par un scan réseau
- Un volume de stockage supplémentaire doit être prévu pour la journalisation



Hybrid IDS

Un IDS hybride rassemble les caractéristiques de plusieurs IDS :

- On place des sondes sur des points stratégiques du réseau
- On place des sondes sur des machines.

C'est une sorte de tout en un : un mélange de HIDS avec un NIDS.



Pourquoi utiliser un IDS hybride ?

Symbiose sur le meilleur des 2 mondes avec les IDS :

- Grâce à ces solutions $\Rightarrow$ faible taux de faux positifs.
- Cela permet aussi dans le cas inverse de détecter des attaques qui ne sont pas encore connues.

Activité de la machine $\rightarrow$ basée sur des règles

Activité sur le réseau $\rightarrow$ basée sur des signatures.

Un flux réseau a impacté une machine, on va créer une nouvelle signature pour l'IDS réseau.



Comparaison NIDS-HIPS-Hybrid IDS

	NIDS	HIDS	Hybrid IDS
Avantages	Contrôle un grand nombre d'hôtes avec un petit coût de déploiement. Identifie les attaques à hôtes multiples. Assure la sécurité contre les attaques puisqu'il est invisible	Contrôle les activités locales des utilisateurs avec précision. Capable de déterminer si une tentative d'attaque a réussi. Fonctionne en environnement chiffré.	Moins de faux positifs. Meilleure corrélation (entre nouvelles en anciennes alertes).
Inconvénients	Incapable de fonctionner dans des environnements chiffrés. Ne permet pas d'assurer si une tentative d'attaque a réussi.	Difficultés de déploiement et de gestion. Incapable de détecter des attaques contre de multiples cibles dans le réseau.	



Des exemples d'IDS

- Snort (libre)
- Splunk (propriétaire)



IPS



IPS (Intrusion Prevention System)

Les systèmes de prévention des intrusions agissent dans la même zone de réseau qu'un pare-feu, c'est-à-dire entre l'extérieur et le réseau interne.

Les IPS rejettent de façon proactive les paquets réseau en fonction d'un profil de sécurité si ces paquets représentent une menace connue.

Il existe 3 types d'IPS :

- **NIPS** (*Network Intrusion Prevention System*)
- **HIPS** (*Host-Based Intrusion Prevention System*)
- **KIPS** (*Kernel Intrusion Prevention System*)



Les types d'IPS

NIPS (*Network Intrusion Prevention System*) :

Il surveille le trafic réseau et peut bloquer des ports dont le trafic semble suspect.

HIPS (*Host-Based Intrusion Prevention System*) :

Il surveille les processus en cours et assure une protection contre les attaques

KIPS (*Kernel Intrusion Prevention System*) :

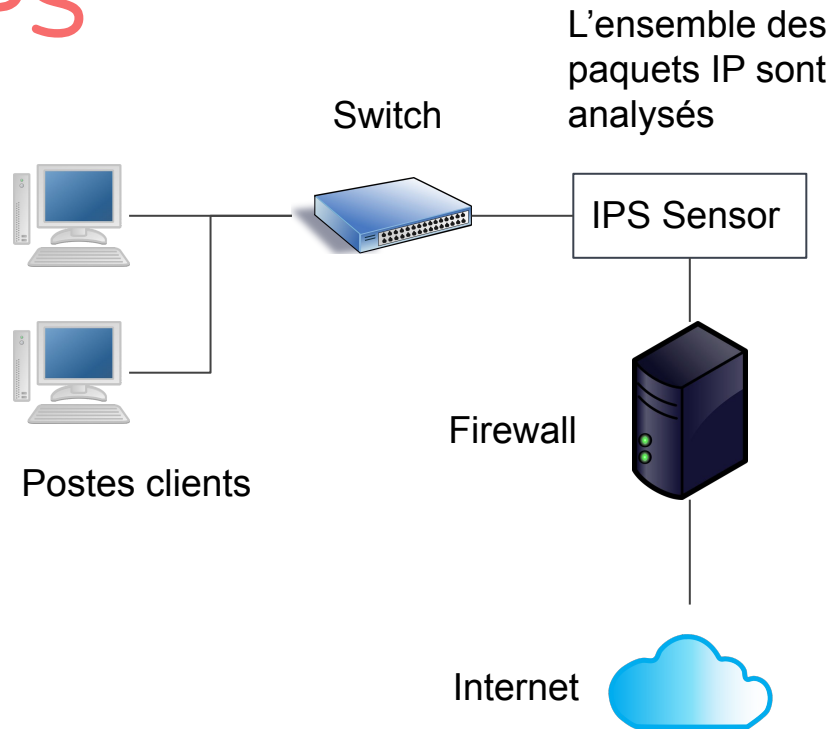
Il peut reconnaître des motifs caractéristiques du débordement de mémoire, et peut ainsi interdire l'exécution du code. Il analyse les appels au système, regarde et interroge le noyau (ralentissements possibles). Il peut interdire à un OS d'exécuter une cmd, d'ouvrir un shell.

Dispositif moins utilisé.



Emplacement d'un IPS

En général, on place l'IPS juste derrière le firewall.





Un moment de réflexion

Que se passe-t-il si l'IPS tombe en panne ?

Mode **fail-open** :

Il transmettra tout le trafic vers le serveur, y compris toutes les attaques possibles.

Mode **fail-close** :

L'ensemble du trafic IP sera supprimé, la machine protégée sera déconnectée du réseau.

Comparaison HIPS-NIPS

	NIPS	HIPS
Avantages	Peut arrêter la propagation des vers si déployé correctement sans arrêter le trafic. Protège contre les nouvelles attaques avant que le code d'exploit soit sorti. Réduit le coût de la réponse aux incidents.	Assure la protection contre les attaques inconnues. Exige peu ou aucune MAJ sur une période annuelle. Empêche les attaques de s'exécuter sur une machine au niveau du noyau.
Inconvénients	Le coût de déploiement au sein d'un réseau peut être important. Un NIPS nécessite toujours des MAJ.	Temps de déploiement long pour équiper chaque machine. Il nécessite un ajustement de configuration après l'installation initiale.



Des exemples d'IPS

- Snort (libre)
- Fail2ban (libre)



Méthodes de détection



Les outils

Les outils et techniques suivants peuvent être utilisés :

- IDS/IPS à base de signature (*Signature-based IDS/IPS*)
- IDS/IPS fondé sur des politiques (*Policy-based IDS/IPS*)
- IDS/IPS basé sur une anomalie (*Anomaly based IDS/IPS*)
- IDS/IPS basé sur la réputation (*Reputation-based IDS/IPS*)



IDS/IPS à base de signature

Une signature recherche une chaîne ou un comportement dans un seul paquet ou flux de paquets pour détecter l'anomalie.

2 types :

- Les signatures orientées vers les exploits identifient les exploits individuels en se déclenchant sur les modèles **uniques** d'une tentative d'exploit particulière ⇒ **correspondance de signature exacte**.
- Les signatures faisant face à la vulnérabilité sont des signatures **plus larges** qui ciblent la vulnérabilité sous-jacente du système ciblé ⇒ **variantes de signatures**
⇒ Augmentation du risque de faux positifs.



IDS/IPS fondé sur des politiques

Fonctionne en fonction de la politique ou du **SOP** (*Standard Operating Procedure*) d'une organisation.

ex :

Protocole telnet pas accepté, règles appliquées sur ces stratégies.

Si configurer sur IPS, telnet généré et paquet abandonné.

Sur IDS alerte généré mais trafic continue à passer car est en mode promiscuité.



IDS/IPS basé sur une anomalie

Création d'une ligne de conduite pour un type spécifique de trafic.

ex :

30 sessions TCP ouvertes toutes les minutes.

- SYN/SYNAC a répondu mais pas d'ACK car le client ne répond pas

⇒ anomalie.

Règle mise en place :

- 35 connexions tcp semi ouverte en 1 temps donné ⇒ l'IPS va supprimer les connexions et générer une alerte.
- Au-delà de 35 connexions la session va automatiquement se fermer

Adaptation de la signature à la politique.



IDS/IPS basé sur la réputation

Collection d'informations auprès des systèmes participant à la corrélation globale.

ex :

Dernier type en attaque déni de service (DoS) sur twitter.

On ajoute descripteur les informations URL, IP, nom de domaines qui la génère et la propage $\Rightarrow$ on interdit l'attaque avant qu'une action soit effectuée.

On va utiliser un scoring mondial.



Résumé des méthodes (part 1)

IDS/IPS	Avantages	Inconvénients
IDS/IPS à base de signature	Facilite la mise en œuvre et la gestion.	Ne détecte pas les attaques qui peuvent contourner les signatures. Peut exiger quelques réglages pour arrêter de générer de faux positifs pour le trafic légitime.
IDS/IPS fondé sur des politiques	Mise en œuvre simple avec des résultats fiables. Tout le reste en dehors du champ d'application de la politique définie sera abandonné.	Exige la mise en œuvre manuelle de la politique. Tout changement plus faible au sein d'un réseau nécessitera un changement de stratégie configuré dans le module IDS/IPS.



Résumé des méthodes (part 2)

IDS/IPS	Avantages	Inconvénients
IDS/IPS basé sur une anomalie	Peut détecter le trafic malveillant en fonction de la ligne de base personnalisée. On peut nier tout type de dernières attaques car elles ne seront pas définies dans le cadre de la politique de référence.	Dans les grands réseaux → Difficile. Il faut une politique de base. Peut générer des faux positifs en raison de la ligne de base mal configurée.
IDS/IPS basé sur la réputation	Utilise les informations fournies dans lesquelles les systèmes partagent leur expérience des attaques réseaux. L'expérience de certains devient une protection pour les autres.	Nécessite des MAJ régulières. La participation de tous les acteurs majeurs pourrait servir de corrélation mondiale dans laquelle les systèmes partagent leur expérience (pas le cas actuellement).



Types de détection



Configuration

Selon le scénario réseau, les modules IDS/IPS sont déployés dans l'une des configurations suivantes :

- Détection d'intrusion basé sur l'hôte (*Host Based IDS/IPS*)
- Détection d'intrusion basée sur le réseau (*Networked Based IDS/IPS*)



Détection d'intrusion basé sur l'hôte

Normalement déployé pour la protection d'une machine spécifique et fonctionne en étroite collaboration avec le noyau de l'OS de la machine hôte. Crée une couche de filtrage pour tout appel d'application malveillante vers l'OS.

Il en existe 4 (IDS/IPS basés sur l'hôte) :

- Surveillance de système de fichiers (*File System Monitoring*)
- Analyse de fichiers journaux (*Log files analysis*)
- Analyse de connexion (*Connection Analysis*)
- Détection de niveau de noyau (*Kernel Level Detection*)



File system monitoring

Dans cette configuration, IDS/IPS fonctionne en comparant étroitement les versions des fichiers dans un certain répertoire avec les versions précédentes du même fichier et vérifie toute falsification et modification non-autorisée dans un fichier.



Log files analysis

Dans cette configuration, IDS/IPS fonctionne en analysant les fichiers journaux de la machine hôte et génère un avertissement pour les administrateurs système responsable de la sécurité de la machine.



Connection analysis

Des exemples de techniques utilisées sont l'analyse des ports ouverts, les connexions TCP semi-ouvertes , etc.



Kernel level detection

Dans cette configuration, le noyau de l'OS lui-même détecte les changements au sein des binaires du système et une anomalie dans les appels systèmes pour détecter les tentatives d'intrusion sur cette machine.



Comparaison des types de détection

	Host Based IDS/IPS	Networked Based IDS/IPS
Evolutivité	Pas évolutif car le nombre d'hôtes sécurisés augmente	Très évolutif. Normalement déployé à la passerelle de périmètre.
Rentabilité	Faible. Plus de systèmes signifient plus de modules IDS/IPS	Haute. Une paire peut surveiller l'ensemble du réseau.
Aptitude	Capable de vérifier si une attaque a réussi ou non	Uniquement capable de générer une alerte d'attaque.
Puissance de calcul	La puissance de traitement du périphérique hôte est utilisée.	Doit avoir une puissance de traitement élevée pour surmonter les problèmes de latence.



Conclusion

Technologies IDS/IPS :

- IDS : NIDS, HIDS, IDS hybride
- IPS : NIPS, HIPS, KIPS

Méthodes de détection : IDS/IPS à base de signature, politiques, anomalie, réputation.

Types de détection : Détection d'intrusion basé sur l'hôte ou sur le réseau

Pour une protection efficace, il est nécessaire d'avoir un IDS et un IPS, l'idéal étant une surveillance hôte et réseau.